

Zenith Global Inc. Governing Artifacts

By Matt Watkins, GRC Advisor/ Analyst

Here are the key operational elements, tools, and strategic artifacts the company and IT director needs to fully secure and govern at Zenith Global:

1. Governance Tools & Automated Monitoring

- **Automated GRC Platform (Governance, Risk, and Compliance):**
 - Systems like **Vanta**, **Drata**, or **LogicGate** to continuously pull live evidence from cloud environments (AWS/Azure/GCP), HRIS systems, and identity providers rather than relying on manual screenshot gathering.
- **Continuous Control Monitoring (CCM):**
 - Automated alerts triggered when a control fails in real time (e.g., an S3 bucket becoming publicly accessible, or an engineer losing MFA status).

2. Critical Operational Artifacts & Plans

- **Incident Response Plan (IRP) & Playbooks:**
 - Step-by-step technical execution runbooks for specific scenarios (e.g., ransomware, active data exfiltration, insider threat, or stolen credentials).
 - Clear escalation protocols specifying who communicates with legal counsel, PR, executive leadership, and law enforcement.
- **Business Continuity & Disaster Recovery (BC/DR) Plan:**
 - Defined **Recovery Time Objectives (RTO)** and **Recovery Point Objectives (RPO)** for all critical production services.
 - Schedule and logs for annual tabletop exercises and automated disaster failover testing.
- **Vendor & Third-Party Risk Management (TPRM) Program:**
 - A structured intake process to evaluate third-party software, SaaS platforms, and contractors before integration.
 - Standardized vendor security questionnaires (e.g., CAIQ or SIG) and mandatory SOC 2 / ISO 27001 review schedules.

3. Organizational & Cultural Governance

- **Security Awareness & Phishing Training Program:**
 - Mandatory onboarding security modules and recurring automated phishing simulations (e.g., via KnowBe4) to measure human risk.
- **Security & Compliance Steering Committee:**
 - A quarterly operational cadenced meeting between the IT Director, Chief Information Security Officer (CISO), Legal Counsel, HR Leadership, and DevOps lead to evaluate high-risk policy exceptions and budget allocation.
- **Acceptable Use Policy (AUP) Signoffs:**
 - Digitally tracked and legally binding acknowledgments signed by every employee and contractor upon hire and during annual reviews.

4. Key Metrics & Executive Reporting (KRI/KPI)

To present risk effectively to Zenith Global's C-suite and board, director needs a live operational dashboard tracking:

Category	Key Metric / Indicator	Target SLA / Goal
Vulnerability SLA	Time to patch Critical/High vulnerabilities	Critical < 7 Days / High < 30 Days
Identity & Access	Deprovisioning SLA for terminated users	< 2 Hours (100% Compliance)
Third-Party Risk	Vendor security reviews completed prior to contract sign-off	100% High-Risk Vendors
Training & Awareness	Phishing simulation click rate	< 3% Organization-Wide
Control Health	Automated continuous control passing rate	> 98% Across All Frameworks